

Labo 1 — Modélisation des Menaces — Trilogie CIA

Scénario : Hôpital National du Wakanda

Groupe:

Date :

Membres du groupe :

1. Objectifs pédagogiques

- Analyser un système réel sous l'angle de la Confidentialité, de l'Intégrité et de la Disponibilité
- Distinguer faiblesse, vulnérabilité, exploit et attaque à partir d'exemples concrets
- Cartographier un scénario d'attaque sur les 5 phases du cycle d'attaque
- Formuler des recommandations de sécurité adaptées au contexte africain

2. Contexte du scénario

L'Hôpital National du Wakanda (HNW) est un établissement public wakandien de 600 lits desservant plus de 400 000 patients par an. En 2024, il a déployé SanteNum, un système de dossiers médicaux électroniques (DME) hébergé dans le cloud via un fournisseur régional basé à Azania (un pays dans la même région).

SanteNum est accessible via navigateur web aux personnels cliniques autorisés. Des interfaces d'intégration relient le système à la pharmacie, au laboratoire d'analyses et au service de facturation. Un ancien serveur sur site synchronise encore les dossiers chaque nuit via un partage réseau non chiffré.

Parties prenantes clés :

- Dr. Aminata Seck — Directrice médicale (accès à distance à l'ensemble des dossiers patients)
- Infirmier-coordonateur Moussa Traoré — gère les plannings de service et les journaux de médicaments
- Admin. informatique Seydou Coulibaly — maintient les serveurs ; accès root au serveur de synchronisation
- Agent de facturation Fatoumata Diallo — accède aux données financières et d'assurance maladie
- Patients — droit à la confidentialité et à l'exactitude de leurs dossiers

3. Partie A — Analyse de la Trilogie CIA

Pour chaque scénario du tableau ci-dessous, déterminez si la Confidentialité (C), l'Intégrité (I) et/ou la Disponibilité (D) sont affectées. Cochez les cases correspondantes et justifiez brièvement. Un scénario peut affecter plusieurs propriétés simultanément.

Scénario	C — Confidentialité	I — Intégrité	D — Disponibilité
Un attaquant devine le mot de passe du Dr Seck et consulte des dossiers patients	☐ Affectée ? _____	☐ Affectée ? _____	☐ Affectée ? _____
Un employé mécontent modifie la liste d'allergies d'un patient dans SanteNum	☐ Affectée ? _____	☐ Affectée ? _____	☐ Affectée ? _____
Un ransomware chiffre la base de données du DME, rendant les dossiers inaccessibles	☐ Affectée ? _____	☐ Affectée ? _____	☐ Affectée ? _____
Le système de laboratoire est saturé de requêtes et devient indisponible pendant 6 heures	☐ Affectée ? _____	☐ Affectée ? _____	☐ Affectée ? _____
Un agent interne transmet des résultats de tests VIH à l'employeur d'un patient	☐ Affectée ? _____	☐ Affectée ? _____	☐ Affectée ? _____
Les dosages de médicaments sont altérés en transit par une attaque de l'homme du milieu	☐ Affectée ? _____	☐ Affectée ? _____	☐ Affectée ? _____
(Scénario libre — à compléter par le groupe)	☐ Affectée ? _____	☐ Affectée ? _____	☐ Affectée ? _____

Q1. Quelle propriété CIA a été la plus souvent violée dans les scénarios ci-dessus ? Pourquoi ce système est-il particulièrement vulnérable à ce type d'attaque dans le contexte d'un hôpital public africain ?

Q2. Identifiez un scénario qui viole simultanément les trois propriétés CIA. Justifiez votre réponse.

4. Partie B — Faiblesses, Vulnérabilités et Exploits

Associez chaque élément de la colonne de gauche à la bonne catégorie.

Élément	Catégorie (écrire : Faiblesse / Vulnérabilité / Exploit / Attaque)
A. La page de connexion de SanteNum n'a pas de mécanisme de verrouillage de compte	
B. Un attaquant exécute un script de bourrage de credentials contre SanteNum	
C. La synchronisation nocturne utilise un partage réseau non chiffré	
D. Le mot de passe faible d'un employé est cracké par force brute	
E. Le serveur web tourne sur une version Apache obsolète avec une CVE connue	
F. Un agent malveillant injecte du SQL dans le champ de recherche pour extraire la BD	

5. Partie C — Phases d'Attaque

Lisez le récit d'attaque suivant, puis associez chaque événement à l'une des cinq phases dans le tableau ci-dessous.

Scenario

Depuis plusieurs semaines, certains employés remarquent des événements inhabituels mais sans y prêter une grande attention. Sur les réseaux sociaux professionnels, plusieurs membres du personnel de l'hôpital publient régulièrement des informations sur leurs fonctions et les outils numériques utilisés par l'hôpital. En parallèle, le service informatique reçoit quelques appels suspects de personnes prétendant être des techniciens du fournisseur cloud demandant des informations sur les logiciels utilisés.

Quelques jours plus tard, l'agent de la facturation (Fatoumata Diallo) reçoit un e-mail semblant provenir d'un partenaire médical habituel. Le message demande de consulter rapidement un document lié à une mise à jour des procédures de facturation. Le fichier joint ne semble pas suspect et Fatoumata l'ouvre depuis son ordinateur professionnel.

Durant les jours suivants, aucun incident majeur n'est signalé. Cependant, certains ordinateurs deviennent plus lents que d'habitude et des connexions inhabituelles sont détectées tard dans la nuit. Des comptes utilisateurs semblent également accéder à des dossiers qu'ils ne consultent normalement jamais.

Un lundi matin, plusieurs services de l'hôpital cessent soudainement de fonctionner. Les médecins ne peuvent plus accéder aux dossiers des patients, les analyses de laboratoire sont bloquées et le système de rendez-vous devient inaccessible. Sur plusieurs écrans apparaît un message indiquant que les données ont été verrouillées et qu'une somme d'argent doit être versée pour rétablir l'accès.

Pendant que les équipes techniques tentent de comprendre l'origine de l'incident, elles découvrent que plusieurs journaux d'activité ont disparu et que certaines connexions proviennent de serveurs situés dans différents pays. En analysant les journaux, les techniciens découvrent que toutes les adresses IP ayant participé à l'activité d'attaque sont des adresses du ministère de la sante du Wakanda (semblant être légitimes).

À partir de ce scénario, identifiez :

- Les éléments correspondant à la phase de reconnaissance ;
 - Les indices permettant d'identifier la cible ;
 - Les actions liées à l'infiltration du système ;
 - Les manifestations de l'exécution de l'attaque ;
 - Les éléments montrant une tentative de déni plausible ou de dissimulation.
-

6. Réflexion de groupe et préparation à la présentation

Votre groupe présentera un résumé de 5 minutes. Préparez des réponses aux questions suivantes :

1. Quelle menace de la Partie A considérez-vous comme la plus grave, et pourquoi ?
2. Choisissez une vulnérabilité de la Partie B et proposez une contre-mesure technique et une contre-mesure organisationnelle.
3. Dans la Partie C, certaines phases ont-elles été difficiles à distinguer ? Lesquelles et pourquoi ?
4. En tant que DSI de l'HNW, quelle propriété CIA protégeriez-vous en priorité ? La réponse d'un patient serait-elle différente ?

Livrables

- Tableau des menaces complété (Partie A) avec cases cochées et Q1–Q2 répondues
 - Exercice d'association complété (Partie B)
 - Tableau des phases d'attaque complété (Partie C) avec Q3 répondue
 - Présentation de groupe de 5 minutes
-